Udyam Digital — data privacy & security note

YTL Hackathon 2026 · Track A · Accel Business (fictional)
Designed against the DPDP Act, 2023 · synthetic data only

Bottom line: **documents are read on the owner's phone and never uploaded**. The server receives only the fields KYC needs, re-checks everything itself, shows and logs identifiers masked, and asks for consent per purpose before any KYC data is touched.

1 What each step collects — and why (purpose limitation, data minimisation)

STEP	DATA	PURPOSE	WHERE IT LIVES
Advisor / chat	Business type, staff count, locations, city, needs; GSTIN optional	Recommend an eligible bundle	Phone (journey choices only); chat state server-side 30 days
Quote	Nothing new	—	Phone
Smart KYC	Extracted fields from GST & Udyam certificates, signatory ID, one utility bill; image quality scores	Telecom KYC and activation only	Images: phone memory only. Fields: server, for verification and the KYC record
e-Sign / order	Order lines, consent ID, masked GSTIN, verdict	Fulfilment and billing	Server (orders table)
Hand-off to a person	Profile without GSTIN, language, stage	Callback in the owner's language	Server (leads), visible to assigned team

2 Consent before KYC

- Plain-language notice in English, Hindi or Marathi: what, why, how, how long, rights.
- Separate toggles: **KYC verification** (required), DigiLocker fetch (optional), offers (optional, **off by default**).
- Stored as a record with timestamp, purposes and notice version (`v1.2`); every order links to its consent ID.
- Withdrawal: `DELETE /api/consent`, exposed on the order page; grievance officer contact on the notice.

3 Minimisation by design

- Blur check, auto-straighten and OCR (self-hosted Tesseract WASM) run in the browser. **No image upload in the default flow.**
- Mock GSTIN/Udyam APIs return only the fields the journey needs.
- AI providers (NVIDIA NIM, Sarvam) receive the business profile with the GSTIN removed. They never receive documents, and they never choose products or prices.
- The optional AI document reader (`/api/kyc/extract`) is off without a key. It would need explicit consent and a data-processing agreement before use.

4 Retention (storage limitation)

- **Document images:** never stored by Accel; released from memory when the tab closes. Extracted fields sit in session storage only until e-sign, then are cleared.
- **KYC record:** kept only as long as telecom KYC rules require, then deleted.
- **Leads that don't convert:** 90 days. **Chat sessions:** 30 days.
- **Audit events:** 1 year, identifiers already masked (e.g. `07CP••••••••1ZT`).

5 Security safeguards

- The server never trusts the client: it re-runs eligibility and pricing on every order and re-validates KYC fields.
- IDs are masked in the UI, logs and partner console. Partners see a lead's business profile, not its documents.
- The browser keeps journey choices only — no IDs and no documents — in local storage.
- Secrets live in environment variables. Every AI call has a hard timeout and a deterministic fallback, so an outage cannot block onboarding.

6 Owner's rights

- Access, correction, erasure and withdrawal from the order page. Grievances acknowledged in 72 hours.
- A human hand-off is always one tap away. No decision is fully automated: KYC failures route to guided fixes or a person.

7 Before production

- Data protection impact assessment (DPIA); encryption at rest (managed Postgres with a key management service); single sign-on and role-based access for the partner console; rate limits.
- Data-processing agreements with AI vendors, preferring India-hosted models. Integrate a registered consent manager and DigiLocker/e-sign providers. Breach-response runbook.

All businesses, people and identifiers in this prototype are synthetic (hackathon data pack). Demo "today" for date checks: 15 Jul 2026, per the data README.